

Module 9: Threat Modeling Exercise (STRIDE)

This threat model identifies **9** distinct threats across 5 STRIDE categories. **Three** are critical (9/10): API credential compromise (cached memory), overprivileged CI/CD role (wildcard IAM), and undetected data exfiltration (no real-time alerting). All threats can be reduced to low risk within 12 weeks through proposed controls. **Critical:** Formal risk acceptance from CISO required for Threat 9 (residual risk).

1. Workload Selection

Name: AWS API Backend + PostgreSQL RDS + S3

Reference: Terragoat (bridgecrewio/terragoat)

Components: Public ALB, private EC2 ASG, encrypted RDS, private S3 buckets, GitLab CI/CD, Terraform IaC

Justification: Typical financial microservice; multi-layer (API, database, storage, identity); exhibits common misconfigurations (IAM overprivilege, public buckets, encryption gaps).

Key Assumptions: No MFA for API clients, CloudTrail enabled but not monitored, manual incident response, no automated alerting.

2. Data Flow

Internet → ALB (no WAF) → EC2 ASG (cached creds) → RDS + S3

↓

CloudTrail Logs (no SIEM)

GitLab Runner (s3:*, ec2:*, rds:*, iam:*) → Terraform State + ECR + Deploy

...

Data at Risk:

- Cached DB credentials in EC2 memory
- S3 buckets with no explicit access policy
- CloudTrail logs not indexed or monitored
- CI/CD credentials in memory for 1+ hour
- Terraform state contains database password

3. STRIDE Threats (9 Total)

#	Threat	Category	Component	Likelihood	Impact	Risk	Controls	Residual
---	-----	-----	-----	-----	-----	-----	-----	-----
1	**API Credential Compromise (Memory)**	Spoofing	EC2 Server	High (3)	Critical (3)	**9**	Secrets rotation (4h), on-demand fetch, EDR	Medium (2)
2	**Overprivileged CI/CD Role**	EoP	GitLab Runner	High (3)	Critical (3)	**9**	Least-privilege IAM, OIDC, supply-chain scan	Low (1)
3	**S3 Public Access**	ID	S3 Bucket	High (3)	High (2)	**6**	Explicit Deny policy, Block Public Access, MFA Delete	Low (1)
4	**Log Tampering**	Tampering	CloudTrail	Medium (2)	High (2)	**4**	Log file validation, MFA Delete, centralized forwarding	Low (1)
5	**DoS via ALB**	DoS	ALB	Medium (2)	High (2)	**4**	WAF + rate limiting, connection timeout tuning, alarms	Low (1)
6	**Terraform State Exposure**	ID	S3 State	Medium (2)	High (2)	**4**	Terraform Cloud, remove secrets from state, HTTPS-only	Low (1)
7	**Cross-Cloud Escalation**	EoP	AssumeRole	Medium (2)	Critical (3)	**6**	External ID, time-bound sessions (15 min), session tags	Low (1)
8	**Malicious Container Image**	Tampering/EoP	ECR/CI/CD	Medium (2)	Critical (3)	**6**	Dependency lock files, Snyk scan, image signing, runtime security	Low (1)
9	⚠️ **Undetected Data Exfiltration**	ID	Monitoring Gap	High (3)	Critical (3)	**9**	Real-time SIEM, RDS monitoring, anomaly detection, DLP	**Medium (2)**

4. Detailed Threat Analysis

Threat 1: API Credential Compromise (Risk 9)

****Attack:**** Application RCE → dump process memory → extract cached DB password, AWS credentials

****Impact:**** Direct database access, bypass audit logging, data exfiltration

****Existing Controls:**** Weak (credentials in memory, no EDR)

****Proposed Controls:****

- Secrets Rotation: Automatic password rotation every 4 hours
- On-Demand Fetching: Application fetches secrets at request time, not startup
- EDR: Deploy Falco for runtime intrusion detection
- Monitoring: CloudTrail alerts on unusual IAM assume-role patterns

****Residual Risk:**** Medium (2) — Even with rotation, 5–10 minute window before expiration; compensating controls (DLP, network monitoring) reduce blast radius.

Threat 2: Overprivileged CI/CD Role (Risk 9)

****Attack:**** Malicious PR or dependency → CI/CD pipeline runs with s3:*, ec2:*, rds:*, iam:* permissions → full AWS compromise

****Impact:**** All production data exposed, persistent access, multi-account breach possible

****Existing Controls:**** None (wildcard policies confirmed in scenario)

****Proposed Controls:****

- Least-Privilege IAM: Replace wildcards with resource-specific ARNs

```
```json
```

```
"Action": ["rds:DescribeDBInstances"],
```

```
"Resource": "arn:aws:rds:region:account:db/prod-api-*
```

```
```
```

- OIDC Workload Identity: Replace long-lived assume-role with short-lived OIDC tokens (10-min TTL)
 - Secrets Scanning: Gitleaks/TruffleHog in pipeline (fail on credentials)
 - Supply-Chain Scanning: Snyk for dependency vulnerabilities
 - Real-Time SIEM: Alert on high-risk API calls (assume-role, modify IAM, RDS modifications)
- **Residual Risk:**** Low (1) — OIDC + resource-specific policies mean attacker must exploit CI/CD platform itself.

Threat 3: S3 Public Access (Risk 6)

- **Attack:**** Enumerate bucket name (DNS, Shodan, GitHub) → call ListBucket/GetObject → exfiltrate audit logs, backups, or snapshots
- **Impact:**** PII exposure, regulatory breach
- **Existing Controls:**** Weak (private bucket, no policy)
- **Proposed Controls:****

- Explicit Deny Policy: Deny all public access at bucket level
 - Block Public Access Settings: Enable all 4 settings at AWS account level
 - MFA Delete: Require MFA to delete bucket versions
 - Access Logging: CloudWatch alerts on unauthenticated ListBucket/GetObject
- **Residual Risk:**** Low (1) — Explicit deny policy + Block Public Access make unauthenticated access impossible.

Threat 4: Log Tampering (Risk 4)

- **Attack:**** Compromise EC2 or CI/CD role → delete CloudTrail logs covering unauthorized access → erase forensic evidence
- **Impact:**** Forensics impossible, attacker covers tracks
- **Existing Controls:**** Encryption at rest (does not prevent deletion)
- **Proposed Controls:****

- CloudTrail Log File Validation: Enable digest verification (cryptographic signing)
- MFA Delete: Require MFA to delete CloudTrail log versions
- Explicit Deny Policy: Deny delete/putobject by any IAM role

- Centralized Forwarding: Stream logs to separate AWS account as they arrive

****Residual Risk:**** Low (1) — Attacker must compromise both production and log archive accounts.

Threat 5: DoS via ALB (Risk 4)

****Attack:**** Send high-volume requests to ALB → exhaust connection slots → service unavailable

****Impact:**** Availability breach, cost escalation (Auto Scaling)

****Existing Controls:**** Auto Scaling (can cause cost runaway)

****Proposed Controls:****

- AWS WAF: Managed rule set + IP reputation blocking

- Rate Limiting: 100 requests/5 minutes per IP

- Connection Tuning: Reduce ALB timeout from 60s to 15s (prevent slow-read attacks)

- Auto Scaling Limits: Set hard cap on max instances (prevent cost runaway)

- CloudWatch Alarms: Alert on spike in 5xx errors

****Residual Risk:**** Low (1) — WAF + rate limiting make large-scale DoS difficult.

Threat 6: Terraform State Exposure (Risk 4)

****Attack:**** Developer downloads state file locally → laptop compromise → attacker extracts DB password

****Impact:**** Direct database access

****Existing Controls:**** Encryption at rest (not in memory on laptops)

****Proposed Controls:****

- Terraform Cloud: Eliminate local state file copies; centralized backend

- Remove Secrets: Use external secrets manager (AWS Secrets Manager); don't store credentials in state

- S3 Encryption: Enforce HTTPS-only access to state backend

- Audit Logging: CloudTrail on state bucket; alert on suspicious access

****Residual Risk:**** Low (1) — Terraform Cloud removes local copies; external secrets manager eliminates credentials from state.

Threat 7: Cross-Cloud Escalation (Risk 6)

****Attack:**** Compromise EC2 → assume privileged CI/CD role → escalate to multi-account admin

****Impact:**** Multi-account compromise

****Existing Controls:**** Assume-role in place (trust policy configuration unknown)

****Proposed Controls:****

- External ID: Add unique, non-guessable external ID to trust policy

```
```\njson
```

```
"Condition": {"StringEquals": {"sts:ExternalId": "unique-secret"}}
```

```
```\n
```

- Time-Bound Sessions: Set duration to 15 minutes (not 1 hour default)

- Session Tags: Restrict permissions based on source environment

- Monitoring: Alert on assume-role calls outside business hours

****Residual Risk:**** Low (1) — Attacker must obtain external ID; sessions are time-limited.

Threat 8: Malicious Container Image (Risk 6)

****Attack:**** Inject backdoor into Dockerfile or compromise dependency → malicious image deployed to all EC2 instances → persistent access

****Impact:**** System compromise, data exfiltration

****Existing Controls:**** Docker build in CI (minimal scanning)

****Proposed Controls:****

- Dependency Lock Files: Pin all versions (package-lock.json, requirements.txt, Pipfile.lock)

- Supply-Chain Scanning: Snyk or Dependabot for vulnerability audits (fail on high severity)

- Container Image Scanning: Trivy before ECR push; block images with critical CVEs

- Image Signing: Cosign to sign and verify image integrity

- Base Image Hardening: Use Alpine or Distroless (minimal attack surface)

- Runtime Security: Falco to detect backdoors (reverse shells, unexpected network connections)

****Residual Risk:**** Low (1) — Multiple detection layers make supply-chain attack detection difficult.

Threat 9: Undetected Data Exfiltration ⚠️ ****RESIDUAL RISK**** (Risk 9 → 2)

****Attack:**** Compromise via Threat 1 or 2 → steal DB credentials → exfiltrate data silently → no alerts for hours/days

****Impact:**** Large-scale data breach

****Current State:**** CloudTrail logs not analyzed; no RDS monitoring; manual log review weeks after incident

****Proposed Controls:****

- Real-Time SIEM: Forward CloudTrail logs within 30 seconds (Splunk, ELK, Security Hub)

- RDS Enhanced Monitoring: Monitor connection spikes; alert if >50 concurrent connections for 5 minutes

- Database Query Logging: Enable PostgreSQL query logging; forward to CloudWatch/SIEM

- Anomaly Detection: AWS GuardDuty or ML-based behavioral analysis

- DLP Solution: Monitor egress traffic; block large data transfers to unknown destinations

- Incident Response Playbook: Automated containment (revoke credentials, isolate RDS, page on-call)

****Residual Risk After Controls:**** Medium (2)

- Detection time: <5 minutes (vs. weeks currently)

- Response time: <15 minutes (automated playbook)

- Exfiltration window: ~10 minutes remains

- Acceptance: YES, if SIEM/alerting is operational, on-call SRE is trained, and DLP is deployed

5. Control Summary

****Preventative (Reduce likelihood):****

- Secrets Rotation & On-Demand Fetching (Threat 1)

- Least-Privilege IAM + OIDC (Threat 2)
- S3 Bucket Policies + MFA Delete (Threats 3, 4, 6)
- WAF + Rate Limiting (Threat 5)
- External ID + Time-Bound Sessions (Threat 7)
- Supply-Chain Scanning + Image Signing (Threat 8)

****Detective (Enable faster response):****

- EDR/Runtime Security (Threat 1)
- Real-Time SIEM (Threats 2, 4, 9)
- CloudTrail Log File Validation (Threat 4)
- RDS Enhanced Monitoring + Anomaly Detection (Threat 9)
- DLP Solution (Threat 9)

****Responsive (Minimize impact):****

- Incident Response Playbook (Threat 9)
- Credential Revocation Automation (All threats)
- Network Isolation (All threats)

6. Implementation Roadmap

Phase	Duration	Actions	Threats Mitigated
Immediate	Wk 1–2	IAM hardening, S3 security, WAF, EDR, CloudTrail validation	T2, T3, T4, T5, T7
Short-Term	Wk 3–6	Secrets rotation, SIEM, RDS monitoring, supply-chain scanning, image scanning	T1, T2, T6, T8, T9
Medium-Term	Wk 7–12	OIDC, Terraform Cloud, GuardDuty, DLP, red team exercise	All (validation)

7. Risk Acceptance Statement (Threat 9)

****Threat:**** Undetected Data Exfiltration

****Current Risk:**** CRITICAL (9/10)

****Post-Mitigation Risk:**** MEDIUM (2/3)

****Acceptance Criteria:****

- [] SIEM operational; CloudTrail logs indexed in real-time (<1 min latency)
- [] RDS Enhanced Monitoring enabled; connection spike alerts <5 min
- [] Database query logging active; anomalies forwarded to SIEM
- [] Incident response playbook documented and tested
- [] On-call SRE trained and available 24/7
- [] DLP solution deployed and monitored (no >10% false positives)

****Risk Owner:**** Chief Information Security Officer

****Review Frequency:**** Quarterly or upon detection system failure

****Rationale:**** Even with residual 1–5 minute exfiltration window, detection time reduction from "weeks" to "minutes" is acceptable. Compensating controls (DLP, network monitoring) further reduce data volume at risk. This risk is formally accepted to maintain compliance deadline.

8. Threat Statistics

****Summary:****

- 9 threats across 5 STRIDE categories (Spoofing, Tampering, Repudiation, ID, DoS, EoP)
- 3 Critical risks (9/10): Threats 1, 2, 9
- 3 High risks (6/10): Threats 3, 7, 8
- 3 Medium risks (4/10): Threats 4, 5, 6
- 25+ recommended controls

- 12-week remediation timeline
- 1 residual risk requiring formal acceptance

****Risk Distribution:****

CRITICAL (9):  33% (3 threats)

HIGH (6):  33% (3 threats)

MEDIUM (4):  33% (3 threats)

****Document Version:**** 1.0

****Classification:**** General

****Next Review:**** [Date + 3 months]